

DOORS Password Policy and MFA Guide

Password lifecycle, TOTP authentication, privileged access and recovery controls

Document control	Value
Document ID	DOORS-SEC-PASSWORD-MFA
Version	1.0
Status	Available
Audience	All human users, Data Manager and Security Administrator
System	DOORS Master API and DOORS UI
Classification	Internal security documentation

Purpose

This guide states the password and multi-factor authentication controls enforced by the current DOORS implementation. It explains what users must provide, how authentication secrets are protected, when sessions are revoked, and how authorized administrators perform recovery.

Security conclusion

A password alone never creates a DOORS portal session. After password verification, the user must complete a time-based one-time password challenge. Password changes, administrator resets, MFA resets and access-governance changes invalidate the active session and require authentication again.

1 Password composition policy

Control	Enforced requirement
Minimum length	12 characters
Maximum length	128 characters
Uppercase	At least one uppercase letter
Lowercase	At least one lowercase letter
Number	At least one numeric digit
Special character	At least one non-alphanumeric, non-whitespace character
Whitespace	Not permitted anywhere in the password
Password change	New password must differ from the current password

The same composition policy applies to user-selected passwords and administrator-issued temporary passwords. Validation returns a specific message for the first failed rule.

2 Password storage and verification

- The browser login payload is protected by the existing DOORS login handshake before the Master API verifies the password.
- The canonical stored credential is BCrypt applied to the SHA-256 digest of the password. The plaintext password is not stored.
- A successful legacy BCrypt-of-plaintext login is upgraded to the canonical BCrypt-of-SHA-256 representation.

- Changing a password requires the authenticated user to provide the current password and a compliant new password.
- After a successful password change, passwordResetRequired is cleared, the current session identifier is removed and the session cookie is cleared.

3 Temporary passwords and forced change

1. An authorized Data Manager or Security Administrator sets a compliant temporary password within their role-governance boundary.
2. DOORS stores the temporary password using the canonical protected representation, sets passwordResetRequired to true and revokes the active session.
3. The user signs in with the temporary password and completes MFA.
4. The authentication filter permits only the password-change workflow until the temporary password is replaced.
5. After the change succeeds, DOORS clears the session and requires a fresh sign-in.

4 TOTP multi-factor authentication

MFA control	Implemented behavior
Method	Time-based one-time password using HMAC-SHA-1
Code	Six numeric digits
Period	30 seconds
Clock tolerance	Current interval plus one interval before and after
Challenge lifetime	Five minutes
Attempt limit	Five failed verification attempts, then the challenge is removed
Enrollment secret	20 cryptographically random bytes encoded as Base32
Authenticator setup	otpauth provisioning URI with issuer DOORS and the user account label
Secret protection	AES-256-GCM using a 12-byte random IV and 128-bit authentication tag

A portal session is issued only after successful TOTP verification. First-time enrollment stores the MFA secret only after the submitted code proves that the authenticator was configured correctly.

5 MFA key and deployment controls

- DOORS_SECURITY_MFA_ENCRYPTION_KEY must be Base64 and decode to exactly 32 bytes.
- When manager-plane enforcement is enabled, startup fails if the development MFA encryption key is still configured.
- The encryption key must be supplied through controlled deployment configuration and must not be placed in documentation, logs or source-controlled production settings.
- Changing or losing the encryption key prevents existing encrypted MFA secrets from being read. Recovery then requires an authorized MFA reset and user re-enrollment.

6 Privileged access checks

- Data Manager, ADMIN and Security Administrator authentication must originate through the permitted manager plane when that enforcement is enabled.
- Data Manager and ADMIN accounts require VPN status CONFIRMED or GRACE_PERIOD.
- When an account has an IP or CIDR allowlist, the current request address must match it.
- Plane, VPN and IP checks are repeated during MFA verification before a session is created.

7 Administrative recovery

Action	Authorization and effect
Password reset	Only an administrator who can govern the target role may set a compliant temporary password. The action forces password change, revokes the session and records PASSWORD_RESET.
MFA reset	Only an administrator who can govern the target role may disable MFA and remove its encrypted secret. The session is revoked, MFA_RESET is audited and the user must enroll again.
IP or VPN change	Authorized governance updates revoke the active session and record the security action.

8 Authentication and session controls

- Login requires a valid, unexpired CAPTCHA before password verification.
- Invalid passwords and MFA codes generate authentication-failure audit events. Successful MFA completion generates an authentication-success event.
- The DOORS_SESSION cookie is HttpOnly, Secure when configured, SameSite Strict, scoped to the application root and limited to eight hours.
- Manual logout clears the stored current session identifier and expires the cookie.
- Role, password, MFA, VPN and IP-governance changes revoke the current session so earlier tokens cannot continue normal use.

9 User and administrator checklist

User checklist	Administrator checklist
Use a unique password that meets every composition rule.	Issue temporary passwords through the governed reset action only.
Complete MFA promptly; a challenge expires after five minutes.	Confirm role-governance authority before password or MFA reset.
Never share passwords, TOTP codes, QR codes or enrollment secrets.	Treat the MFA encryption key as a production secret and back it up securely.
Report unexpected MFA enrollment or repeated failures.	Review PASSWORD_RESET, MFA_RESET, LOGIN_FAILURE and LOGIN_SUCCESS audit events.
Sign in again after password or MFA recovery.	Verify privileged plane, VPN and IP requirements after recovery.